

UST-2026-09-30-27

Acceso al hub, a StartUp Admin y a las salas Builders/Pitch tras el aviso de una tester: se cierra la cerradura de cartón de Design (esta noche), y después tres llaves en orden — PIN de Cloudflare por correo · contraseña · tercera llave (3 posiciones de una clave de 8 o TOTP) — con sesión de 24 horas como máximo y una sola sesión abierta por persona

PROPUESTA (30-sep-2026, madrugada) · Entrega A (cerrar el desbloqueo por longitud de Design) lista para desplegar en cuanto Juanjo diga D1 · Entrega B (tres llaves, 24 h, una sesión) se construye tras la validación fila a fila de D1–D14. Antes que nada: D13 — comprobar en Cloudflare la política Include y los Logs de Access.

1 · El pedido, literal

Juanjo (chat de Claude Code, 30-sep-2026 ~00:05 y ~00:40), tras el aviso de una tester («they were able to access the builders page») y sus propias pruebas en Chrome incógnito, escritorio e iPhone:

«We have an urgent task to do tonight, it has been reported by one of our testers that they were able to access the builders page, I have tried myself and I have observed the following behaviours».

«1. In Incognito Mode in Chrome, I tried to use random digits and didn't go through, today's six digit code is [seis cifras], ACTION: to reinforce it: let's make it 8 digits and change it to [ocho cifras] and ask for three random digits».

«2. I observed that in Desktop and Mobile after going through the random digits authentication and email cloudflare in desktop (that's OK) and in mobile going straight to the builders (not asking for email OTP, doesn't seem OK), I go through the user/password authentication in both platforms (that is OK), ACTION, set the default tap for opening the builders in Piloto, startup admin in the landing page as it is, but without user/password authentication nothing should be shown».

«3. After going through the two digits authentication is presenting the claudfare email OTP challenge and response, no issues observed in the Desktop Chrome but in the Mobile (IOS/iPhone) it is not asking for the email OTP, ACTION: put all behind the user and password first, second cloudfare OTP authentication, and third three out of six digits or the MFA as for the three digits out of six».

«4. let's put back OTPT optional, we will get always the user/password, cloudfare email OTP, random 3 pins and/or OTPT (optional) if OTPT is activated the random 3 pins would not be asked for».

«The startup admin, is asking for a six digit email OTP, the Pitch access should ask for the same, but all behind Cloudfare email OTP authentication instead of supabase six digits, so StartUp Admin and Pitch, should ask first for email and password for authentication, second for email OTP as second factor authentication and third the 3 random digits out of 8 or the TOTP (MFA authenticator)».

«Finally the session should not last more than 24 hours».

(~00:40) «and adding to all the improvements, only one session can be open at a time».

Lectura de ingeniería: (a) hay un agujero REAL pero pequeño — la cerradura de Design debajo de la nuestra — que se cierra con un cambio de una línea y un deploy (Entrega A); (b) el resto del pedido es un REDISEÑO de la autenticación de las tres superficies privadas (hub, StartUp Admin, salas) que deshace tres de las siete decisiones de UST-17 «un candado» (26-sep): vuelven la tercera llave y el cierre de sesión, y la sesión de Access baja de 30 días a 24 h. Es carril técnico (decide Juanjo), pero Pilar, Lucía y María Paula lo notan cada día: por eso D12 les pide probar el circuito ANTES de que caduque la primera sesión, para no repetir el 26-sep («no me deja entrar»). Dos puntos del pedido no se pueden construir tal cual y se proponen de otra forma: el ORDEN (Cloudflare Access va siempre primero porque vive en el borde de la red, antes de que exista una página donde teclear una contraseña — D2) y las CLAVES (las dos cifras del pedido han pasado por el chat y quedan quemadas por la regla del 4-sep; las nuevas las teclea Juanjo en el SQL y viven en el gestor compartido — D5).

Lo que el pedido llama «OTP de Cloudflare» y «OTP de Supabase» (dos códigos distintos, como el 26-sep)

El PIN que llega al Gmail al entrar en /hub/* o en admin. lo manda Cloudflare Access (segundo factor, sesión por dispositivo). El código de seis cifras que hoy pide StartUp Admin lo manda Supabase (signInWithOtp, sustituye a la contraseña). El pedido quiere que StartUp Admin use contraseña + PIN de Cloudflare, como el hub, y retirar el OTP de Supabase (F6, D9).

Lo que NO es un fallo

«En el móvil no pide el OTP por correo»: la cookie de Access dura 30 días por dispositivo (UST-17 D2, hecho en Zero Trust por Juanjo el 26-sep). En incógnito no hay cookie y sí lo pide. Con D6 (24 h) lo pedirá cada día en cada dispositivo.

2 · Lo que hay HOY (medido esta madrugada: curl a producción, código servido, integrate.py, RPC y tests)

Qué	Medido
Entrada a las salas	Pie de la Web V2 → `/v1/?sala=builders` o `/v1/?sala=pitch` (bloque `ns-sala-deeplink`) → tarjeta de Design con NUESTRA cortinilla `ns-room-gate` (r14i): 6 puntos, dos posiciones al azar elegidas por el NAVEGADOR, teclado barajado, `POST /rest/v1/rpc/ns_room_gate_check` con la anon key (la RPC lee `room_gate`, tabla RLS sin políticas; el código no está en el HTML — lo vigila web-tests r14h). Al acertar: `location.href = /hub/full-hub-gated-site.html?r=builders` → Cloudflare Access. Sin límite de intentos: con posiciones elegidas por el cliente, 300 llamadas bastan para recuperar el código entero.
EL AGUJERO	En el motor de Design (`/v1/index.html`, texto plano): `verifyHub: () => { if (this.state.hubCode.length === 6) { this.setState({ hubUnlocked: true }) ... } }` — mira la LONGITUD, no el valor (`hubCode: ""`, sin comparación). Nuestra cortinilla esconde su ` <input >`="" (`builderstack`,="" (su="" ...`,="" 900="" `="" `display:none`="" a="" abren="" access:="" access»,="" al="" app»="" apuntan="" blanco="" botón="" cada="" cambiar="" cifras="" con="" cualesquiera="" de="" del="" demo)="" desde="" design="" detrás="" el="" en="" esconder="" ese="" estado:="" estática="" founder).<="" full="" herramientas="" hub="" hueco,="" iframe="" la="" las="" los="" motor="" ms,="" navegador,="" no="" o="" page="" para="" pero="" pitch="" placeholder="Enter code" quien="" quitando="" redibuja="" repo="" room»="" sala="" sea="" seis="" su="" td="" the="" vuelve="" y="" «builder="" «explore="" «open="" «request="" →="" ↗»=""/>
Lo que está cerrado (medido)	`/hub`, `/hub/`, `/hub/index.html`, `/hub/full-hub-gated-site.html` (con y sin `?r=`), `/hub/pilot.html`, `/hub/pitch.html`, `/hub/admin-mis-console.html`, `/hub/mfa.html`, `/hub/investors-business-case.html` → 302 a `larama-familia-2026.cloudflareaccess.com`. `nutrisync-collective.pages.dev/hub/...` → 301 al dominio (r26-c). `admin.nutrisynccollective.com` → 302 a Access. `/builders` y `/pitch` → 200, pero sirven la Home de la V2 (78 KB, sin cortinilla ni contenido de sala).
Access (capa 1)	Política del hub: 8 correos (foto en `hub/access.html`: 2 de Juanjo, 2 de Lucía, 2 de Pilar, 2 de María Paula; la verdad es el panel). Sesión: «1 month» global y en las dos aplicaciones (UST-17 D2). El team domain es de la cuenta (también aloja laramagonzalez.com).
Hub (capa 2)	Contraseña de Supabase (`signInWithPassword`) UNA vez por dispositivo; el refresh token renueva sin fin; cierre por inactividad APAGADO (`LIMITE=0`, UST-17 D3). 28 de las 29 páginas de /hub llevan su propio bloque de login (MIS: overlay `adminLogin`; herramientas: `id="gate"`), pero el contenido ESTÁTICO se pinta antes de la contraseña — en el gated de Design (Overview/Builders) se ve la sala entera tras Access sin sesión; los DATOS llegan por RPC y esas RPC exigen `is_admin_mfa()` = «es admin» (UST-17 D1/D5: ya no mira `aal`). `ns-default-route`: sin hash → `#/builders`. TOTP: opcional, `nsMfaReforzar()` en la barra, `mfa.html`; ninguna RPC lo exige.
StartUp Admin (admin.)	Access → `signInWithOtp` de Supabase (código de 6 cifras por correo, `shouldCreateUser:false`) → `verifyOtp` dentro; TOTP opcional con aviso clicable; `LIMITE=0`. `is_sa_admin()` = «es admin». `admin-tests` vigila que la ÚLTIMA definición de `is_sa_admin` no mire `aal` (test «un candado») y la forma de `afterSignIn`.
Sesiones	Access 30 días/dispositivo. Supabase: JWT de 1 h + refresh token sin caducidad absoluta. Cliente: sin límite absoluto. Es decir: hoy una sesión del hub dura hasta que alguien cierra sesión a mano. OJO: los ajustes de sesión del panel de Supabase (Authentication → Sessions: time-box, single session) son de TODO el proyecto — la app y la PWA de las testers usan el MISMO Supabase — así que no sirven para limitar solo a las admins.
Baseline (lo que se restaura)	Web en producción po267 (`ns-build 2909-233153`, webdeploy `b2e5cc6`, desplegada 29-sep 23:5x) · proyecto `b0cc280` (adminsita dentro) · appdev `5741f18` · RPC: `ns_room_gate_check` (2026-08-06-room-gate.sql), `is_admin_mfa` / `is_sa_admin` (2026-09-26-un-candado-auth.sql), `admin_mfa_readiness` (2026-08-05) · Access «1 month» (panel) · Supabase Sessions por defecto (panel). Marcha atrás web: Pages → Deployments → Rollback; SQL: `create or replace` a la definición anterior (idempotente); paneles: volver a «1 month» / desactivar time-box.

Analogía: Es una puerta con una cerradura buena (Access) y, dentro, un armario con dos cierres: el nuestro, que pregunta al servidor, pegado encima de uno de cartón que se abre empujando. La tester empujó el de cartón y vio el interior del armario — no la casa. Esta noche se quita el de cartón; después se decide cuántas llaves lleva la casa y cuánto dura cada una abierta.

3 · Lo que se construiría (F1–F10) — Entrega A esta noche · Entrega B tras la firma

Qué	Qué se construye	Cómo se verifica
F1 · ENTREGA A · Cerrar la cerradura de cartón de Design (D1)	En el bloque <code>`ns-room-gate`</code> de <code>`integrate.py`</code> , sobre el índice de la v1: <code>`verifyHub: () => { if (this.state.hubCode.length === 6) {` → `if (false) {`</code> . La sala de Design deja de abrirse desde su propio botón; la única forma de «entrar» sigue siendo nuestra cortinilla, que no abre la sala: salta al hub (Access). Nada más cambia: ni la cortinilla, ni las tarjetas, ni el estilo (la segunda aparición de <code>`hubCode.length === 6`</code> es el color del botón y se queda). <code>web-tests r27-p: `publish/v1/index.html`</code> NO contiene <code>`hubCode.length === 6`</code> . Deploy po268.	Puerta: <code>web-tests</code> en rojo con el fichero de hoy y en verde con el cambio. Vivo: en <code>`/v1/?sala=builders`</code> , con el <code>`display:none`</code> retirado a mano, teclear seis cifras + «Verify & enter» NO abre nada; la cortinilla sigue mandando al hub (Access). <code>smoke-prod: check</code> nuevo «v1: sin desbloqueo por longitud».
F2 · ENTREGA B · Clave de 8 cifras y reto de 3 posiciones que elige el SERVIDOR, con límite de intentos (D4, D5, D11)	<code>`room_gate.code`</code> pasa a 8 cifras (<code>`__CLAVE_PUERTA_8`</code> : la teclea Juanjo en el SQL antes de Run; no va a git ni al chat). Nueva <code>`ns_room_challenge()`</code> → <code>`{challenge_id, positions[3]}`</code> guardado en <code>`room_gate_challenges`</code> (uuid, posiciones, <code>`ip_hash`</code> de <code>`request.headers`</code> , <code>`created_at`</code> , <code>`used`</code> ; caduca a los 3 min). <code>`ns_room_gate_check(p_challenge uuid, p_digits text)`</code> : UN intento por reto, compara las 3 cifras, marca <code>`used`</code> ; si en 15 min hay ≥5 fallos para ese <code>`ip_hash`</code> → <code>`{ok:false, wait:true}`</code> hasta que pasen. La cortinilla pide las posiciones que devolvió el servidor (8 puntos, 3 marcados) y enseña «espera unos minutos» si hay bloqueo. La RPC vieja de 2 posiciones se retira en el mismo SQL (la web nueva sale a la vez: SQL → Deploy).	Arnés <code>`tools/sql-arnes/2026-09-30-tres-llaves/`</code> : reto caduca · reto no se reutiliza · 5 fallos bloquean (rojo) · acierto entra (verde) · posiciones fuera de rango → false. Vivo: incógnito, 5 fallos seguidos → bloqueo con mensaje; tras 15 min, entra. El código de la puerta no aparece en <code>`publish/`</code> (<code>web-tests r14h</code> , ampliado a 8 cifras).
F3 · Tercera llave del hub, exigida en el SERVIDOR (D3, D10)	Clave de equipo de 8 cifras (<code>`team_key`</code> , <code>`__CLAVE_EQUIPO_8`</code> , distinta de la de la puerta si D4 = dos) y <code>`ns_team_key_challenge()/`ns_team_key_check()`</code> SOLO para <code>`authenticated`</code> (después de la contraseña), mismo patrón de reto/límite que F2 (5 fallos/15 min por usuaria). Al acertar, fila en <code>`admin_key_ok(user_id, session_id = auth.jwt()->'session_id', verified_at)`</code> . <code>`is_admin_mfa()`</code> e <code>`is_sa_admin()`</code> v3: <code>`es admin AND (aal = 'aal2' OR existe admin_key_ok para ESTA sesión con verified_at > now() - 24 h)`</code> . Así la tercera llave no es un adorno de la interfaz: sin ella, ninguna RPC admin responde. Si la cuenta tiene un factor TOTP verificado, la barra pide el TOTP ( <code>`nsMfaReforzar`</code> , ya existe) y NO la clave (D10).	Arnés SQL: <code>`is_admin_mfa()`</code> devuelve false con sesión aal1 sin fila; true con fila de esta sesión; false con fila de OTRA sesión o de hace 25 h; true con aal2. <code>admin-tests</code> : la última definición de <code>`is_sa_admin`</code> exige <code>`aal2 OR admin_key_ok`</code> (el test «un candoado» se reescribe: hoy exige lo contrario). Vivo: tras la contraseña, sin la llave, el MIS enseña el reto y no datos.
F4 · Un solo muro para todo /hub (D8)	El login sale de las 28 páginas y pasa a la BARRA (<code>`hub-navbar.html`</code> , que ya está en todas): al cargar cualquier /hub, el <code>`<body>`</code> se oculta hasta tener (1) sesión de Supabase y (2) tercera llave de esta sesión (o aal2). Sin sesión → pantalla completa con correo + contraseña; con sesión sin llave → reto de 3 posiciones (u overlay TOTP). El gated de Design incluido: su contenido estático ya no se ve tras Access sin contraseña. Los bloques de login de cada página quedan (no molestan) y se retiran en goteo.	<code>web-tests r27-p</code> : la barra contiene el muro y todas las páginas /hub la llevan (ya se cuenta). <code>jsdom</code> : sin token → <code>`body`</code> oculto y formulario visible; con token sin llave → reto; con llave → contenido. Vivo: incógnito → Access → contraseña → llave → contenido, en esa secuencia, en escritorio e iPhone.
F5 · Pestaña por defecto: Piloto (D7)	La cortinilla salta a <code>`/hub/pilot.html`</code> (hoy <code>`?r=builders`</code>) y <code>`ns-default-route`</code> sin hash manda a <code>`pilot.html`</code> en vez de <code>`#/builders`</code> . La pestaña Overview (gated de Design) sigue en la barra para quien la quiera. StartUp Admin sigue donde está en la landing.	<code>web-tests</code> : <code>`HUB=`</code> de la cortinilla y el destino sin hash apuntan a <code>pilot.html</code> . Vivo: puerta → ... → Piloto.
F6 · StartUp Admin: contraseña en vez del OTP de Supabase; PIN de Cloudflare como segundo factor; tercera llave igual que el hub (D9)	<code>`repos/adminsite/index.html`</code> : <code>`bindGate`</code> pasa de <code>`signInWithOtp`/`verifyOtp`</code> a <code>`signInWithPassword`</code> ; tras entrar, <code>`afterSignIn`</code> exige la tercera llave (TOTP si hay factor; si no, 3 de 8 contra <code>`team_key`</code>) y <code>`is_sa_admin()`</code> v3 lo respalda. Deploy StartUp Admin (su <code>`command`</code>).	<code>admin-tests</code> : <code>`signInWithOtp`</code> desaparece de <code>`afterSignIn`/`bindGate`</code> ; <code>`signInWithPassword`</code> presente; forma nueva de <code>`afterSignIn`</code> . Vivo: admin. → Access → contraseña → llave → libros.
F7 · Pitch = el mismo circuito que Builders	La sala Pitch solo tiene contenido dentro de /hub (iframe y «Open full page ↗»); con F1 su cortinilla de cartón muere, con F4 el hub pide contraseña + llave. No hace falta una puerta aparte.	Vivo: <code>`/v1/?sala=pitch`</code> → cortinilla → hub → muro → llave → Pitch.
F8 · Sesión de 24 h como máximo y UNA sesión por persona, SOLO para las admins (D6, D14)	Los ajustes de sesión del panel de Supabase (time-box, single session) NO se tocan: son de todo el proyecto y cerrarían cada día la app a las testers del piloto. Se hace con lo nuestro: (1) Cloudflare Zero Trust → Settings → Authentication → sesión global 24 h, y Access → Applications → hub y admin → Session Duration 24 h (panel, Juanjo; deshace UST-17 D2); (2) la fila de <code>`admin_key_ok`</code> caduca a las 24 h y es ÚNICA por persona: al verificar la llave en un dispositivo se borran las filas anteriores → la sesión antigua deja de pasar <code>`is_admin_mfa()`</code> en el siguiente RPC (una sola sesión, en el servidor); (3) la barra y adminsite llaman a <code>`admin_session_ok()`</code> (RPC ligera: ¿hay fila viva para ESTA sesión?) al cargar y cada 2 minutos: si no la hay, muro con el motivo («han pasado 24 h» o «has entrado desde otro dispositivo»); (4) cliente: <code>`ns_login_ts`</code> y cierre absoluto a las 24 h por si el servidor no contesta. El JWT de Supabase sigue vivo (a la app no le afecta), pero sin fila no hay hub. Inactividad: sigue apagada (<code>`LIMITE=0`</code>) salvo que D6 diga lo contrario.	Arnés SQL: segunda verificación de la llave desde otra <code>`session_id`</code> borra la primera; <code>`admin_session_ok()`</code> false para la sesión vieja; fila de hace 25 h → false. Panel: captura de los ajustes de Access. Vivo: entrar en el iPhone estando dentro en el Mac → el Mac vuelve al muro en ≤2 min; a las 24 h de la llave, el muro con el aviso. Sonda: <code>`admin_key_ok`</code> tiene UNA fila por admin.

Qué	Qué se construye	Cómo se verifica
F9 · Documentación y avisos	`hub/access.html` (texto: tres llaves, 24 h, una sesión; la lista de correos sigue siendo foto), `documentation/user-guide` (línea de acceso), `CONTINUIDAD-Llaves-Compartidas.md` (las dos claves nuevas van al gestor compartido, NO al fichero), mensaje de una línea para Pilar, Lucía y María Paula (qué cambia mañana y por qué), Notion sin bloques → hub, CLAUDE.md (invariantes de seguridad: sustituyen a las de «un candado»).	web-tests: access.html sin «30 days». Mensaje enviado (WhatsApp, lo manda Juanjo).
F10 · Tests y puertas	web-tests r27-p (F1, F4, F5), admin-tests (F3, F6), arnés SQL (F2, F3), smoke-prod (v1 sin desbloqueo por longitud; admin. sigue tras Access; /hub/* sigue 302), `datos-en-html` (sin datos nuevos a mano), linkcheck.	Todas en verde en el Deploy; smoke en verde tras el deploy.

4 · Análisis de impacto

Dónde	Qué toca	Qué NO toca
Web (`repos/webdeploy`)	`integrate.py` (bloques `ns-room-gate` y `ns-default-route`), `_integration/hub-navbar.html` (muro + tercera llave + 24 h), `_integration/access.html` (texto), `docs/62-...` (este documento) · publish/ por Deploy: po268 (A) y po269+ (B).	
StartUp Admin (`repos/adminsite`)	`index.html` (`bindGate`, `afterSignIn`, `LIMITE` → cierre absoluto 24 h) · Deploy StartUp Admin.	
Base (`backend-sql`)	`2026-09-30-tres-llaves-a.sql` (nada: A es solo web) · `2026-09-30-tres-llaves-b.sql`: `room_gate` 8 cifras + `room_gate_challenges` + `ns_room_challenge` / `ns_room_gate_check` v2 (anon, con límite) · `team_key` + `ns_team_key_challenge` / `ns_team_key_check` (authenticated) · `admin_key_ok` · `is_admin_mfa` / `is_sa_admin` v3 · tablero. Placeholders `__CLAVE_PUERTA_8__` y `__CLAVE_EQUIPO_8__` que teclea Juanjo antes de Run (D5). Arnés `tools/sql-arnes/2026-09-30-tres-llaves/`.	
Paneles (Juanjo)	Cloudflare Zero Trust: política Include del hub y de admin. (D13, comprobar) · sesión global y de las dos aplicaciones a 24 h (D6) · Logs de Access (D13). Supabase: NADA en Authentication → Sessions (son ajustes de todo el proyecto; la app de las testers los sufriría).	
Tests	`tools/web-tests.mjs` (+r27-p; se ajusta r14h a 8 cifras), `tools/admin-tests.mjs` (test «un candado» → «tres llaves»: la última definición exige aal2 O llave), `tools/smoke-prod.mjs` (+2 checks), arnés SQL nuevo.	
Quién lo nota	Pilar, Lucía, María Paula y Juanjo: cada día y en cada dispositivo, PIN de Cloudflare por correo + contraseña + tercera llave (TOTP o 3 cifras) — UNA vez, y después 24 h sin retos. Cambiar de móvil a portátil cierra la sesión del otro (D14). Las testers y el público: nada (la web, la app y la PWA no cambian).	
Lo que NO se toca	RLS y las políticas de datos, `service_role` (solo Vault/Edge), las 8 páginas legales, la app y la PWA, el rebote de pages.dev, la waitlist (UST-19), los correos de Access (los 8 de la foto: si el panel dice otra cosa, es D13 y no esta UST). No se rota ninguna credencial (UST-21 D0: nada hasta noviembre) — las claves de la puerta y del equipo son NUEVAS, no rotaciones.	

Estimación: Entrega A, 20 minutos (hecha, pendiente de D1 y del doble clic). Entrega B, una jornada: SQL + arnés (media), barra + adminsite + tests (media), verificación en dos dispositivos con Pilar y Lucía. Riesgo principal: el del 26-sep al revés — cuatro retos en fila dejaron fuera a las founders; por eso B se entrega en UN día, con los tres relojes a 24 h a la vez y con las founders probando ANTES de la primera caducidad (D12).

5 · Decisiones (D1–D14: Juanjo, carril técnico; Pilar y Lucía corroboran y prueban — D12) — propuesta · alternativa

#	Propuesta	Alternativa	Decisión
D1	Entrega A esta noche: neutralizar el desbloqueo por longitud de Design y desplegar po268 (un cambio de una línea, sin efecto en nada más).	Esperar y desplegar A junto con B.	

#	Propuesta	Alternativa	Decisión
D2	ORDEN de las llaves: Cloudflare Access (PIN por correo) → contraseña de Supabase → tercera llave (TOTP si hay factor; si no, 3 de 8). Access va primero por construcción: vive en el borde de la red, antes de que exista una página donde teclear. La fuerza es la misma que en el orden del pedido; lo que cambia es que ningún desconocido llega siquiera al formulario de la contraseña.	Orden literal del pedido (contraseña → PIN de Cloudflare → llave): exige sacar el formulario de contraseña a una URL PÚBLICA fuera de Access (más superficie expuesta, misma fuerza). No recomendada.	
D3	La tercera llave se exige en el SERVIDOR: <code>`is_admin_mfa()` / `is_sa_admin()` v3 = admin AND (aal2 OR llave verificada en esta sesión ≤24 h)</code> . Sin llave, ninguna RPC admin responde aunque alguien salte la interfaz.	Solo en la interfaz (la barra pide la llave, las RPC no la comprueban). Más simple, pero una llave que no vigila el servidor es un adorno.	
D4	DOS claves de 8 cifras: la de la PUERTA pública (salas; anónimos, con límite de intentos) y la del EQUIPO (tercera llave, solo tras la contraseña). Si un día se adivina la de la puerta, no se ha adivinado nada del hub.	UNA sola clave para puerta y tercera llave (más fácil de recordar; una fuga en la puerta pública debilita el hub).	
D5	Las claves NO viajan por el chat ni por git: el SQL lleva <code>`__CLAVE_PUERTA_8__`</code> y <code>`__CLAVE_EQUIPO_8__`</code> , Juanjo las teclea antes de Run y las guarda en el gestor compartido (ficha nueva en CONTINUIDAD). Las dos cifras del pedido de esta noche se dan por quemadas (regla del 4-sep: un secreto en el chat es un secreto quemado).	Usar tal cual la clave de 8 del pedido (ya ha pasado por el chat y por este documento en cifrado: no recomendada).	
D6	Sesión de 24 h SOLO para las admins, con dos relojes nuestros y uno de Cloudflare: Access global + las dos aplicaciones a 24 h (panel), la llave (<code>`admin_key_ok`</code>) caduca a las 24 h y lo comprueba el servidor en cada RPC, y la barra cierra a las 24 h con aviso. Los ajustes de sesión del panel de Supabase NO se tocan (son de todo el proyecto: echarían a las testers de la app cada día). Inactividad sigue APAGADA (la del 26-sep). Deshace UST-17 D2/D3; se declara.	Además, cierre por inactividad a los 30 min (UST-06 G1): más retos al día para las founders. Solo si Juanjo lo quiere.	
D7	Pestaña por defecto: Piloto (<code>`/hub/pilot.html`</code>) tanto desde la cortinilla como sin ruta; ▢ Overview sigue en la barra; StartUp Admin sigue donde está en la landing.	Dejar <code>`#/builders`</code> (Overview de Design) como hoy.	
D8	Muro universal en la barra: en TODA página de /hub (incluido el gated de Design) no se pinta NADA hasta tener sesión y llave; los bloques de login de cada página se retiran en goteo.	Muro solo en las herramientas con datos (MIS, Piloto, Waitlist...); el gated de Design se sigue viendo tras Access.	
D9	StartUp Admin: contraseña de Supabase (<code>`signInWithPassword`</code>) en vez del código de 6 cifras por correo; el PIN de Cloudflare ya es el segundo factor; tercera llave igual que el hub. La misma puerta en las dos superficies.	Mantener el OTP de correo de Supabase ADEMÁS de la contraseña (cuatro retos: el 26-sep otra vez).	
D10	TOTP opcional: si la cuenta tiene factor verificado se pide el TOTP (la sesión pasa a aal2) y NO la clave de equipo; sin factor, la clave. Nadie pierde su factor; <code>`mfa.html`</code> sigue.	Siempre la clave de equipo, tenga o no TOTP.	
D11	Límites de intentos: puerta pública 5 fallos/15 min por IP (hash) y un intento por reto (3 min); clave de equipo 5 fallos/15 min por usuaria. Mensaje honesto («espera unos minutos»), no silencio.	Sin límite (como hoy): el reto de posiciones se recupera entero en unas cientos de llamadas.	
D12	Corroboración y PRUEBA de Pilar y Lucía: el mismo día del deploy de B, entran desde móvil y escritorio siguiendo el What to Test, y Juanjo confirma en los Logs de Access. Mensaje de una línea preparado (F9).	Desplegar y avisar después (el 26-sep fue exactamente esto).	
D13	ANTES de A: Juanjo mira en Zero Trust la política Include del hub y de admin. (deben ser los 8 correos) y los Logs de Access (ningún correo ajeno). Si aparece uno: incidente aparte (UST propia, rotación y aviso a Audidat), no esta UST.	Darlo por bueno sin mirar.	

#	Propuesta	Alternativa	Decisión
D14	UNA sesión abierta por persona, SOLO para las admins: la fila de `admin_key_ok` es única por persona — verificar la llave en un dispositivo borra la del anterior, que pierde el hub en el siguiente RPC (≤ 2 min) y ve el muro con «has entrado desde otro dispositivo». NO se usa «Single session per user» del panel de Supabase: es de todo el proyecto y cerraría la app a cualquier tester que la abriera en dos dispositivos. Access no tiene este ajuste, y no hace falta: sin llave no se ve nada (D3, D8).	No limitar; solo las 24 h.	

6 · Baseline, verificación y marcha atrás

Momento	Qué se comprueba
A · antes del deploy	web-tests r27-p en rojo con el fichero de hoy y en verde con el cambio; pre-deploy, datos-en-html, linkcheck en verde; zip po268 solo cambia `v1/index.html` (+ sello) y el doc 62.
A · tras el deploy	<code>curl `v1/` : 0 apariciones de `hubCode.length === 6` { ` ; cortinilla intacta ( ` ns-room-gate` , ` ns_room_gate_check`); smoke-prod verde; a mano: seis cifras en el input de Design no abren nada.</code>
B · antes	Arnés SQL (F2, F3) en verde con los casos en rojo probados; admin-tests y web-tests nuevos; Deploy Web + Deploy StartUp Admin con sus puertas; capturas de los tres ajustes de panel.
B · después	Incógnito escritorio + iPhone: Access → contraseña → llave → Piloto; 5 fallos → bloqueo; la llave en el móvil cierra el Mac en ≤ 2 min; a las 24 h, el muro. La app de una tester sigue abierta (nada del proyecto cambió). Logs de Access: solo los 8 correos. Pilar y Lucía: «entro» desde los dos dispositivos (D12).
Registro	Doc 62 as-built con desviaciones fila a fila; PDF firmado + ` .sha256` ; tablero (` 2026-09-30-tres-llaves-tablero.sql` , item P0 en S19); CLAUDE.md; Notion sin bloques → hub.

7 · What to Test (Pilar, Lucía, María Paula — tras la Entrega B)

- Escritorio, ventana de incógnito: nutrisynccollective.com → pie → Builders → completa las TRES posiciones marcadas de la clave de la puerta (8 puntos). Debe pedir el PIN de Cloudflare por correo, luego tu contraseña del hub y luego tu tercera llave (el código de tu app de autenticación si la tienes; si no, tres posiciones de la clave del equipo). Después: Piloto, sin más preguntas.
- iPhone, Safari: lo mismo. Al verificar tu llave en el iPhone, la sesión del escritorio se cierra sola en un par de minutos (una sesión por persona): en el Mac aparece el muro con el aviso «has entrado desde otro dispositivo».
- Falla la clave 5 veces seguidas: debe decir que esperes unos minutos; a los 15 vuelve a dejarte.
- Al día siguiente (24 h después de entrar): vuelve a pedir PIN + contraseña + llave, con un aviso que lo explica. Antes de esas 24 h, nada.
- admin.nutrisynccollective.com: PIN de Cloudflare → contraseña → llave → libros. Ya no llega el código de 6 cifras por correo de Supabase.
- Si algo no entra, di QUÉ pantalla y a QUÉ hora (captura): cada capa deja rastro distinto (Logs de Access · auth de Supabase · admin_key_ok).

8 · Lecciones grabadas (van también a CLAUDE.md)

Lección	Qué cambia
Una cerradura buena encima de una de cartón es una de cartón	Nuestra cortinilla preguntaba al servidor, pero dejaba VIVO el botón de Design que solo mira la longitud. Tapar no es neutralizar: lo que hay debajo se desactiva (F1), y la prueba lo intenta por debajo (input destapado).
«En el móvil no lo pide» se mide antes de llamarlo fallo	Era la sesión de 30 días por dispositivo decidida el 26-sep. Ante un síntoma de autenticación, primero: ¿qué cookie/sesión lleva ese dispositivo? (r23, r27-c).
Un factor que solo vive en la interfaz no es un factor	La tercera llave se exige en `is_admin_mfa()` / `is_sa_admin()` (D3); si no, cualquiera que salte el overlay llama a las RPC igual.
Las claves no pasan por el chat	Las dos cifras del pedido quedan quemadas (regla del 4-sep). Placeholders en el SQL, la clave la teclea quien la custodia y vive en el gestor compartido (D5).

Lección	Qué cambia
Cuatro retos en fila = cero retos (26-sep) — y la cura no es quitar retos, es UNO al día	Tres llaves, una vez cada 24 h, en las dos superficies con la misma puerta; y las founders prueban antes de la primera caducidad (D12).
`PEDIDO.extra` son objetos {titulo, texto}	UST-23/24/25 los escribieron como cadenas y el generador los pintó en blanco (lo cazó la verificación del 29-sep). Este documento los escribe como objetos; los tres anteriores se corrigen aparte (texto firmado: se avisa a las founders).

9 · La cadena

Paso	Estado
UST	Este documento (propuesta, 30-sep madrugada) · D1–D14 fila a fila · Entrega A y B separadas.
Sign-off	Juanjo (D1–D14, carril técnico) · Pilar y Lucía corroboran y PRUEBAN (D12) · María Paula avisada (entra igual).
Dev	A: `integrate.py` + web-tests (hecho, pendiente de D1). B: SQL + arnés → barra + `ns-default-route` + access.html → adminsite → tests.
Test	web-tests r27-p · admin-tests «tres llaves» · arnés SQL con casos en rojo · pre-deploy · smoke-prod (+2 checks).
Deployment	A: Deploy Web po268. B: SQL en la bandeja (con las claves tecleadas por Juanjo) → Deploy Web → Deploy StartUp Admin → panel de Access (24 h global y en las dos aplicaciones).
Verification	Incógnito + iPhone, 5 fallos, cambio de dispositivo, 24 h · Logs de Access · sonda `auth.sessions`.
hub + Notion	Doc 62 (propuesta → as-built) + adjunto; ítem P0 en S19 (`2026-09-30-tres-llaves-tablero.sql`); Notion sin bloques → hub; CLAUDE.md (invariantes nuevas, UST-17 D1–D3 superadas).

Firmas

Persona	Rol	Conforme	Fecha
Juanjo Cebrián	Ingeniería y producto — decide D1–D14 (carril técnico)	PENDIENTE (fila a fila)	
Pilar González	CEO — corrobora y PRUEBA el circuito (D12); dueña de la organización de Supabase	PENDIENTE (corroboración + prueba)	
Lucía Cebrián	COO — corrobora y PRUEBA el circuito (D12)	PENDIENTE (corroboración + prueba)	